5교시 · 전 · 어디로 들어오나

가장 약한 고리는 사람

주소를 읽는 규칙 · 보낸 사람 확인 · 열쇠 하나의 대가

실습 준비 — netsec 폴더에서 실습합니다. 이 시간에 나오는 **가짜 주소는 전부 지어낸 것**이며 실제로 접속하지 않습니다. **문자열만 분석**합니다.

이 시간의 목표

기술적으로 아무 문제가 없어도 뚫리는 경로를 확인합니다. 1교시의 **DNS(전화번호부)**가 어떻게 무기가 되는지, 그리고 **눈이 아니라 규칙으로** 판단하는 법을 익힙니다.

01 오늘 배우는 것

개념	일상적인 비유	한 줄 설명
등록 도메인	주소의 진짜 주인	호스트의 **마지막 두 조각**입니다. (co.kr처럼 꼬리가 두 조각이면 세 조각) 앞에 무엇을 붙이든 주인은 바뀌지 않습니다.
피싱	똑같이 생긴 가짜 간판	사람은 주소 전체가 아니라 **눈에 띄는 몇 글자**만 봅니다. 그 습관을 정확히 노립니다.
표시 이름 (From)	봉투 겉면에 손으로 쓴 글씨	**아무나 원하는 대로 적을 수 있습니다.** 메일 프로그램은 이것을 크게 보여줍니다.
SPF · DKIM · DMARC	그 글씨가 진짜인지 검사한 결과 도장	각각 **보낸 서버가 맞는지 / 내용이 위조되지 않았는지 / 둘을 종합해 어떻게 할지**를 봅니다.
자격증명 재사용	모든 문에 같은 열쇠	어느 한 곳에서 유출된 비밀번호가 나머지 전부를 엽니다. 그래서 **2단계 인증이 복잡한 비밀번호보다 효과적**입니다.

02 실습 — 직접 해보기

1 주소를 조각내는 함수 만들어 보기

조작 대화형 모드에서 직접 조각내 봅니다.

```
Windows  python
>>> from lab5_url_check import dissect, registrable_domain
>>> dissect("https://naver.com.login-page.xyz/verify")
```

관찰 호스트는 `naver.com.login-page.xyz`인데 주인은 **login-page.xyz**로 나옵니다.

의미 규칙은 한 줄입니다 — **점으로 자른 뒤 뒤에서 두 조각.** 눈이 아니라 이 규칙으로 판단해야 합니다.

2 왜 뒤에서부터 읽는지 확인하기

조작 registrable_domain 함수를 열어 읽습니다. 다섯 줄입니다.

```
parts = host.split(".")
tail2 = ".".join(parts[-2:])
# co.kr 처럼 꼬리가 두 조각이면 세 조각을 쓴다
```

관찰 앞쪽(www, naver.com)은 **누구나 붙일 수 있는 이름표**입니다.

의미 도메인은 **오른쪽으로 갈수록 상위**입니다. 그래서 주인은 항상 **끝**에 있습니다.

3 자동으로 수상한 신호 찾아내기

조작 여러 주소를 넣어 어떤 경고가 나오는지 확인합니다.

```
>>> from lab5_url_check import explain
>>> explain("https://www.paypa1.com/account")
>>> explain("http://toss-refund.co.kr.secure-pay.net/claim")
```

관찰 **'paypa1'은 'paypal'을 흉내 낸 것, 점이 지나치게 많음** 같은 경고가 자동으로 붙습니다.

의미 l↔1, o↔0, m↔rn은 **눈으로는 거의 구분되지 않습니다.** 그래서 기계에게 시킵니다.

4 열 문제로 내 눈 시험하기

조작 스크립트를 실행하면 마지막에 10문제 퀴즈가 나옵니다. 진짜면 y, 가짜면 n.

```
Windows  python lab5_url_check.py
Mac/Linux  python3 lab5_url_check.py
```

관찰 대부분 **7~8개**쯤 맞힙니다. 틀린 문제의 진짜 주인을 기록표에 적으세요.

의미 여기서 틀리는 게 정상입니다. **"나는 안 속는다"는 확신이 가장 위험합니다.**

5 메일의 진짜 발신자 확인하기

조작 sample_headers.txt의 세 통을 분석합니다. 그다음 **내 메일함에서 아무 메일이나** 원본 보기를 열어 붙여 넣어 봅니다.

```
>>> from lab5_url_check import read_sample_file, read_headers
>>> read_sample_file()
```

관찰 표시 이름은 "KB국민은행 보안센터"인데 실제 도메인은 kb-secure-notice.info 입니다.

의미 메일 프로그램은 **표시 이름을 크게, 실제 주소를 작게** 보여줍니다. 그 배치를 노린 수법입니다.

6 가장 까다로운 세 번째 메일 뜯어보기

조작 3번 메일의 검사 결과 세 줄만 다시 봅니다.

```
Received-SPF: pass   ← 통과!
dkim=fail            ← 서명 불일치
dmarc=fail           ← 종합 실패
```

관찰 SPF만 보면 정상입니다. 하지만 **서명(DKIM)이 깨졌고 Return-Path가 회사와 다릅니다.**

의미 하나만 보고 판단하면 속습니다. 실제 사내 사칭 메일이 이런 모양입니다. **첨부를 열기 전에 전화로 확인**하는 것이 유일한 대책입니다.

7 열쇠 하나의 대가 계산하기

조작 종이에 내가 자주 쓰는 서비스 5개를 적고, 그중 **같은 비밀번호를 쓰는 곳**에 동그라미를 칩니다.

관찰 동그라미가 2개 이상이면, 그중 **가장 허술한 곳**이 뚫리는 순간 나머지도 함께 넘어갑니다.

의미 유출은 **내가 잘못하지 않아도** 일어납니다. 내가 통제할 수 있는 건 **"하나가 뚫려도 거기서 끝나게 만드는 것"**뿐입니다.

03 관찰 기록표

퀴즈에서 **틀린 문제**만 적으세요. 왜 속았는지 한 줄로 쓰면 다음에 안 속습니다.

주소	내 판단	정답	진짜 주인	속은 이유
1				
2				
3				
퀴즈 점수		/ 10	—	—

메일 세 통을 분석한 결과입니다. **표시 이름과 실제 도메인이 다른 줄**을 찾으세요.

메일	표시 이름	실제 도메인	SPF / DKIM / DMARC	판정
1번				
2번				
3번				

04 복습 확인

1. `https://mail.naver.com.session-check.top/` 의 진짜 주인은 _____ 이다.
2. 주소에서 진짜 주인을 찾는 규칙을 한 문장으로 적어 보자.
3. 메일의 '보낸 사람' 이름을 믿으면 안 되는 이유는 무엇인가?
4. SPF는 통과했는데 DKIM과 DMARC가 실패했다. 어떻게 판단해야 하는가?
5. 비밀번호를 20자리로 복잡하게 만드는 것과 2단계 인증을 켜는 것 중 무엇이 더 효과적인가? 왜인가?

정답

1) session-check.top · 2) "**첫 번째 단독 슬래시 앞까지가 호스트, 그 호스트의 마지막 두 조각이 주인**" (co.kr 등은 세 조각) · 3) 표시 이름은 **보내는 사람이 마음대로 적는 글자**이고 검증 대상이 아니기 때문 · 4) 사칭 가능성이 높다. 서명이 깨졌다는 것은 **내용이 위조됐거나 다른 서버가 대신 보냈다**는 뜻이므로, 전화 등 다른 경로로 확인해야 한다 · 5) **2단계 인증.** 비밀번호는 아무리 복잡해도 유출되면 그대로 쓰이지만, 2단계 인증은 비밀번호가 유출돼도 한 겹이 더 남는다.

05 혼자 복습하는 법

01 **코드를 다시 돌립니다.** lab5_url_check.py의 퀴즈만 다시 풀어 점수가 올랐는지 봅니다. (2분)

02 **내 메일함에서 한 통.** 아무 메일이나 원본 보기를 열어 실제 도메인과 검사 결과를 확인합니다.

03 **소리 내어 설명합니다.** 주소에서 진짜 주인을 찾는 규칙을 **보지 않고** 말해 봅니다.

아래 표는 **보지 않고** 채워 보세요. 비유까지 함께 적을 수 있으면 완전히 이해한 것입니다. 채운 뒤 01번 표와 맞춰 봅니다.

오늘의 용어	내 말로 설명해 보기 (비유를 넣어서)
등록 도메인	
피싱	
표시 이름 (From)	
SPF · DKIM · DMARC	
자격증명 재사용	

06 막혔을 때

코드 실습에서 오류는 실패가 아니라 **정상 과정**입니다. 아래에서 증상을 먼저 찾으세요.

증상 · 오류 메시지	원인	해결
ModuleNotFoundError: No module named '_width'	파일이 다른 폴더에 있음	netsec 폴더의 파일을 **모두 같은 곳**에 두고 실행하세요.
sample_headers.txt 파일이 없다고 나옴	실행 폴더가 다름	`dir`(Win) / `ls`(Mac)로 파일이 보이는 곳에서 실행하세요.
내 메일 헤더를 넣었더니 (없음)이 많음	메일 서비스마다 헤더 이름이 조금 다름	Gmail은 '원본 보기', 네이버는 '원문 보기'에서 **전체**를 복사해야 합니다.
퀴즈 답을 입력해도 넘어가지 않음	y 또는 n 이외의 값 입력	y 또는 n 만 입력하고 엔터를 누르세요.
가짜 주소가 궁금해서 접속해 보고 싶음	—	**절대 접속하지 마세요.** 실습용으로 지어낸 주소지만, 실제로 누군가 등록했을 수 있습니다.
한글이 깨져서 나옴	터미널 인코딩 문제 (구형 Windows)	`chcp 65001` 을 먼저 실행한 뒤 스크립트를 돌리세요.

한 줄 정리

사람이 읽는 건 주소 전체가 아니라 **눈에 띄는 몇 글자**이고, 메일의 보낸 사람 이름은 **아무나 적을 수 있습니다.** 그래서 눈이 아니라 **규칙과 검사 결과**로 판단해야 합니다.

→ **다음 시간** 위험은 다 봤습니다. 이제 **오늘 당장 무엇을 할지** 점검 리포트 한 장으로 정리합니다.

아래 여백은 메모 공간입니다.